KỊCH BẢN THUYẾT TRÌNH & DEMO BẢO MẬT

Hệ Thống Quản Lý Đào Tạo EduFlaw — Tiêu Chuẩn OWASP Top 10:2025

Học phần: Cơ sở An toàn thông tin
Nhóm sinh viên: Nhóm 7 (Khóa D24 - PTIT)
Giảng viên hướng dẫn: ThS. Đỗ Xuân Chợ

1. CẤU TRÚC BUỔI THUYẾT TRÌNH BẢO VỆ BTL (TỔNG 15 PHÚT)

Thời lượng	Nội dung trọng tâm	Thao tác thực hiện	Mục tiêu cần đạt
MÀN 1 (3 phút)	Kiến trúc & Mô hình đe dọa	Trình chiếu Slide bài báo cáo	Trình bày 4 lỗ hổng OWASP 2025: A01 (IDOR), A03 (Supply Chain), A07 (Auth), A10 (Fail-Closed).
MÀN 2 (4 phút)	Demo ứng dụng Web thực tế	Nhấp đúp `1_CHAY_WEB_DEMO.bat`	Biểu diễn phân quyền 3 vai trò: Master, Giảng viên (nhập điểm), Sinh viên (xem điểm).
MÀN 3 (4 phút)	**Live Pentest Console (Trọng tâm)**	Nhấp đúp `4_CHAY_KIEM_THU_PENTEST.bat`	**Biểu diễn console kiểm thử an toàn thông tin** (Chặn dò mật khẩu HTTP 429, 0 lỗi 5xx).
MÀN 4 (4 phút)	Pháp chứng CSDL & Hỏi đáp	Bảng Audit Log + Trả lời phản biện	Minh chứng số CCCD mã hóa AES-256-GCM, bảo vệ toàn vẹn điểm số và phản biện chuyên sâu.

2. KỊCH BẢN CHI TIẾT PHẦN LIVE DEMO (MÀN 3 — TRỌNG TÂM)

💡 **Thao tác:** Tại thư mục gốc dự án, **nhấp đúp chuột vào** `4_CHAY_KIEM_THU_PENTEST.bat`. Cửa sổ màu đen chuyên nghiệp xuất hiện. Sau đó bạn gõ số bài tương ứng:

BÀI 3 **Kiểm Thử Chống Brute-Force & Khóa Tài Khoản (OWASP A07:2025)**

Thao tác: Tại menu chính, bạn gõ số `3` rồi bấm **Enter**.

LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:

"Kính thưa Thầy, em xin biểu diễn kịch bản phòng thủ lỗ hổng Xác thực A07. Kẻ tấn công sử dụng công cụ dội thử liên tiếp 7 mật khẩu sai vào tài khoản sinh viên b24dcat001. Như Thầy thấy trên màn hình: Từ lần 1 đến lần 4, máy chủ báo sai mật khẩu (HTTP 200). Đúng đến lần thứ 5, hệ thống kích hoạt cơ chế khóa bảo vệ, trả về mã HTTP 429 Too Many Requests và khóa cứng IP cùng tài khoản trong 60 giây. Các lần thử 6 và 7 đều bị từ chối ngay lập tức."

BẢN CHẤT KỸ THUẬT & KẾT QUẢ ĐO ĐẠC:

- **Thời gian phản hồi:** Các lần thử bị khóa phản hồi cực nhanh (chỉ từ 6ms - 19ms), giúp máy chủ không bị tốn tài nguyên CPU xử lý mật khẩu băm.
- **Cơ chế khóa kép (Dual-Scope Lockout):** Máy chủ lưu vết cả `ip:127.0.0.1` và `user:b24dcat001@eduflaw.com` trong bảng CSDL `login_attempts`. Dù tin tặc đổi IP bằng VPN/Proxy thì tài khoản sinh viên vẫn được bảo vệ nguyên vẹn.

BÀI 2 Kiểm Thử Xử Lý Ngoại Lệ & Nguyên Tắc Fail-Closed (OWASP A10:2025)

Thao tác: Bấm Enter quay lại menu, gõ số `2` rồi bấm **Enter**.

LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:

"Tiếp theo là kịch bản kiểm thử xử lý điều kiện ngoại lệ A10. Em gửi liên tục 23 payload độc hại gồm SQL Injection, XSS, Path Traversal, Null Byte và chuỗi dài 10.000 ký tự vào API xác thực để ép máy chủ phát sinh lỗi. Kết quả đạt 0 lỗi 5xx trên toàn bộ 23 payload, độ trễ trung bình chỉ 20ms. Hệ thống bắt toàn bộ ngoại lệ theo nguyên tắc Fail-Closed: đóng cửa an toàn, không crash server và tuyệt đối không để lộ Stack Trace ra ngoài."

BẢN CHẤT KỸ THUẬT & KẾT QUẢ ĐO ĐẠC:

- **Chuỗi rỗng / Khoảng trắng:** Bị chặn ngay từ tầng xác thực định dạng, trả về `HTTP 400 Bad Request` (chỉ 24ms).
- **Buffer Overflow (Chuỗi 10.000 ký tự):** Xử lý an toàn trong 26ms, không xảy ra tràn bộ nhớ hay treo tiến trình Python.
- **0 Lỗi 5xx (Internal Server Error):** Chứng minh nhóm không dùng câu lệnh thô thiếu `try/except`, ngăn chặn hoàn toàn việc hacker đọc thông báo lỗi để suy ra cấu trúc bảng CSDL.

BÀI 4 Điều Tra Pháp Chứng CSDL & Tính Toàn Vẹn Dữ Liệu Lưu Trữ (Data-at-Rest)

Thao tác: Bấm Enter quay lại menu, gõ số `4` rồi bấm **Enter**.

LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:

"Để chứng minh an toàn ở tầng lưu trữ CSDL, em truy vấn trực tiếp vào MySQL cục bộ: Thứ nhất, toàn bộ trường số CCCD của sinh viên đều hiển thị dưới dạng chuỗi mã hóa tiền tố enc:v1: bằng thuật toán AES-256-GCM. Dù kẻ trộm có lấy được toàn bộ file Database thì số CCCD vẫn vô nghĩa nếu không có Secret Key. Thứ hai, bảng nhật ký kiểm toán ghi vết chi tiết việc giảng viên sửa điểm từ 6.5 lên 8.0 với đầy đủ thời gian và lý do phúc khảo, đảm bảo tính toàn vẹn và bất khả chối bỏ."

BẢN CHẤT KỸ THUẬT & KẾT QUẢ ĐO ĐẠC:

- **Mã hóa AES-256-GCM (Field-level Encryption):** Không dùng khóa cố định mà kết hợp Secret Key với Nonce ngẫu nhiên. Mỗi lần mã hóa cùng 1 số CCCD sẽ tạo ra chuỗi băm khác nhau, chống tấn công dò tìm mẫu (Frequency Analysis).
- **Audit Trail:** Ràng buộc mọi thao tác `UPDATE` trên cột điểm thi bắt buộc phải ghi 1 bản ghi vào bảng `grade_audit_logs`, không ai có thể can thiệp điểm ngầm.

BÀI 1 Quét Endpoint & Nhận Diện Bề Mặt Tấn Công (Attack Surface Mapping)

Thao tác: Bấm Enter quay lại menu, gõ số `1` rồi bấm **Enter**.

LỜI THOẠI THUYẾT MINH TRƯỚC HỘI ĐỒNG:

"Nhóm thực hiện Fuzzing 69 đường dẫn để tự động xác định ranh giới xác thực. Toàn bộ 23 route nghiệp vụ của sinh viên, giảng viên và quản trị viên đều phản hồi mã HTTP 302 chuyển hướng về trang đăng nhập. Các file cấu hình nhạy cảm như .env, .git, db.sql đều trả về 404 không tồn tại. Đồng thời công cụ chỉ ra chính xác đường dẫn debug /console của Werkzeug đang mở, chứng minh khả năng rà quét phát hiện điểm yếu của công cụ."

3. BỘ CÂU HỎI PHẢN BIỆN CỦA GIẢNG VIÊN & CÂU TRẢ LỜI CHUẨN "ĐIỂM 10"

❓ Câu hỏi 1: Tại sao nhóm chọn khóa tài khoản trong 60 giây mà không khóa vĩnh viễn luôn?

Trả lời: Thưa Thầy, theo tiêu chuẩn NIST SP 800-63B và OWASP, việc khóa vĩnh viễn tài khoản sau vài lần nhập sai sẽ vô tình biến cơ chế bảo mật thành một lỗ hổng Từ chối dịch vụ (Denial-of-Service - DoS). Kẻ tấn công chỉ cần dùng mã sinh viên công khai để gõ sai mật khẩu hàng loạt sinh viên, làm toàn bộ trường bị khóa tài khoản và không thể thi cử. Vì vậy nhóm chọn chính sách **Khóa lũy tiến theo thời gian (Exponential Backoff / Rate-limit 60s)**: đủ dài để làm tê liệt các công cụ dò quét tự động (1 triệu mật khẩu mất vài năm), nhưng người dùng thật vẫn có thể đăng nhập lại sau khi chờ đợi.

❓ Câu hỏi 2: Nếu kẻ tấn công dùng nhiều IP (Distributed Botnet) để dò mật khẩu thì hệ thống giải quyết thế nào?

Trả lời: Thưa Thầy, hệ thống EduFlaw áp dụng cơ chế **Dual-Scope Throttle (Khóa kép 2 tầng)** trong bảng `login_attempts`. Khi có request đăng nhập thất bại, hệ thống tăng đồng thời 2 bộ đếm: `ip:<dia_chi_ip>` và `user:<ten_tai_khoan>`. Nếu kẻ tấn công đổi sang hàng nghìn IP khác nhau nhưng cùng nhắm vào một tài khoản sinh viên, bộ đếm `user:...` sẽ chạm ngưỡng 5 lần và khóa tài khoản đó trên toàn bộ mọi địa chỉ IP. Ngược lại, nếu tin tặc từ 1 IP dò mật khẩu của nhiều sinh viên khác nhau, bộ đếm `ip:...` sẽ khóa toàn bộ request từ IP đó.

❓ Câu hỏi 3: Khóa bí mật dùng để mã hóa số CCCD được lưu ở đâu? Nếu hacker dump được CSDL thì có giải mã được không?

Trả lời: Thưa Thầy, khóa mã hóa CCCD (`SECRET_KEY`) được tách biệt hoàn toàn khỏi Database và chỉ được lưu trữ dưới dạng biến môi trường trong file `.env` trên hệ điều hành máy chủ. Kẻ tấn công dù khai thác được lỗ hổng SQL Injection hay Dump được toàn bộ file sao lưu CSDL thì trong bảng `student_profiles` cũng chỉ thu được các chuỗi ngẫu nhiên `enc:v1:...`. Nếu không chiếm được quyền root trên máy chủ ứng dụng để đọc khóa AES, dữ liệu danh tính cá nhân của sinh viên vẫn an toàn tuyệt đối.

❓ Câu hỏi 4: Nhóm làm thế nào để đảm bảo Giảng viên không tự ý sửa điểm rồi xóa vết trong CSDL?

Trả lời: Thưa Thầy, hệ thống đảm bảo tính Bất khả chối bỏ (Non-repudiation) qua 3 lớp: 1. Giảng viên chỉ có quyền `UPDATE` bảng điểm của lớp mình phụ trách (A01 - Chống IDOR). 2. Mỗi thao tác lưu điểm đều tự động tạo 1 bản ghi vào bảng `grade_audit_logs` ghi rõ người sửa, giờ sửa, điểm cũ, điểm mới và lý do. 3. Giảng viên hoàn toàn không được cấp quyền `DELETE` trên bảng `grade_audit_logs`. Chỉ tài khoản Master mới có quyền giám sát bảng này nhưng cũng không có quyền sửa chữa nhật ký.

❓ Câu hỏi 5: Tại sao ở Bài 1 công cụ lại phát hiện lộ route debug /console (HTTP 200)?

Trả lời: Thưa Thầy, đây là điểm nhóm cố tình thiết kế để kiểm thử khả năng nhận diện điểm yếu. Trong môi trường Development, Flask bật `debug=True` nên Werkzeug mở console tương tác tại `/console`. Khi chuyển sang môi trường Production (như nhóm đã cấu hình trong `config.py`), cờ `ENV=production` sẽ tự động tắt hoàn toàn debugger, bật cờ Cookie Secure và đóng route này, trả về mã 404 cho kẻ tấn công.